HL-CYB-001

Advanced engineering assignment: Enterprise Zero Trust Security Architecture

Enterprise Zero Trust Security Architecture

Document version b71778f12e42

Contents

1. Description and background 3

2. Enterprise scenario and business case 3

3. Purpose, objectives, and learning goals 3

4. Measurable technical requirements 4

5. Scope, exclusions, assumptions, and constraints 5

6. Prerequisites and dependencies 6

7. Expected architecture and trust boundaries 6

8. Technologies and implementation alternatives 7

9. Security requirements and threat model 7

10. Standards alignment 8

11. Deliverables and final outcomes 8

12. Testing and acceptance 8

13. 100-point evaluation rubric 8

14. GitHub publication requirements 9

15. Evidence-backed resume achievement objectives 9

16. Authoritative references 10

Table 1. Document

Field	Value
Project ID	HL-CYB-001
Difficulty	Advanced
Discipline	Cybersecurity engineering, enterprise architecture, and technical business analysis
Current phase	Planning and repository bootstrap; implementation NOT STARTED
Assignment baseline	2026-11-05, owner timezone America/Toronto
Assessment model	Evidence-based engineering assessment followed by separate owner UAT
Publication	Public, reviewed artifacts in `waqashamdani-ca/enterprise-zero-trust-security`

1. Description and background

Staff need access to business services without gaining unnecessary access to other systems. In this assignment, a synthetic Purple Eye organization has analysts, engineers, and administrators with different responsibilities. The lab must support their approved work, restrict other actions, and produce evidence that explains each access decision.

Design an isolated lab, then build and evaluate it in separately approved stages. Apply Zero Trust principles: check identity and permission for the requested resource rather than treating network membership as permission. Combine identity, device controls, network restrictions, application permissions, and audit records. Explain the lab's limits, including the absence of resilient identity services, continuous device attestation, hardware-protected certificate authority keys, or a staffed monitoring function. Use NIST SP 800-207 and the project glossary for terminology.

2. Enterprise scenario and business case

Model three roles: an analyst reads synthetic reports, an engineer maintains a test application, and an administrator manages infrastructure through a dedicated path. Also create an unauthorized synthetic user and a remote user whose access will be revoked. These accounts support negative tests: checks that an action is denied. Use no real employees, customer names, company directory, corporate sign-in, or production records.

The business case is a repeatable place to evaluate access restrictions and recovery before considering an enterprise deployment. Reuse the supplied hardware, control resource use, explain design decisions, and show how audit records support an investigation. Compare the connections allowed before and after the lab policies. Report actual observations; do not invent breach-reduction percentages, savings, availability, or organization-wide security outcomes.

3. Purpose, objectives, and learning goals

Produce a justified architecture, an operational lab in later approved stages, and evidence against the stated business requirements. The learner will:

1. Turn role-specific workflows into an asset inventory, access boundaries, measurable requirements, and acceptance tests.
2. Separate virtual systems and control their network connections without changing home or production networking.

3. Build a lab directory, Domain Name System (DNS), endpoint baseline, and public key infrastructure (PKI), with supported recovery procedures.
4. Compare identity-aware remote-access approaches using permitted and denied cases.
5. Connect access-policy decisions to device and network audit events using synthetic activity.
6. Automate selected repeatable operations and verify recovery and documentation accuracy.
7. Explain tradeoffs, verified results, limits, and unresolved risks in a public portfolio.

The learning goals relate to Certified Information Systems Security Professional (CISSP) domains: security/risk management, asset security, architecture, network security, identity/access management, assessment/testing, operations, and software development security. This is an educational mapping, not certification credit or an endorsed course.

4. Measurable technical requirements

Lab requirements below are **PLANNED**. Completed repository/documentation work is recorded in the individual task reports, beginning with T1. Use the requirement IDs unchanged when linking implementation, tests, evidence, and acceptance. The test procedures are in TEST-PLAN.md; approval and acceptance gates are in ACCEPTANCE-CRITERIA.md.

Table 2. Measurable technical requirements

ID	Required outcome and measurement	Future evidence / tests	Stage
R01	Zero production trust, identity sync, credential reuse, customer data, or lab paths into protected home/production assets; demonstrate configuration review plus mock-boundary denial	Approved topology, route/NAT review, T01, T02	A-D, K
R02	Inventory verified CPU/virtualization, NICs, disk ownership/free space, and recovery path; initial VM disks at most 248 GiB and guest RAM at most 36 GiB, subject to measured capacity	Sanitized readiness report and capacity ledger, T03	A, B
R03	Restrict hypervisor/firewall administration to the lab administrative path; named administrator, supported MFA, least privilege, and tested emergency console access	Redacted role/management policy and console check, T04	B, D
R04	Implement at least six separate lab trust zones; every inter-zone permit has owner, direction, destination, service, and justification; all unmatched traffic denied	Rule inventory and allowed/denied flow evidence, T05, T06	C, D, H
R05	Separate `ad.lab.test` forest, lab DNS and GPO; at least six synthetic standard users in three role groups plus two separate privileged lab accounts; no external trust	Synthetic object summary, DNS/GPO outputs, T07, T08	E
R06	At least one supported Windows member endpoint and one supported Linux endpoint; host firewalls enabled, updates recorded, no ordinary-user local administration	Baseline and privilege checks, T09	F
R07	Offline standalone root and separate online issuing CA; issue a scoped lab TLS certificate; validate trust, expiration, and revoked-certificate rejection in a selected supported relying application	CA design, redacted template review, lifecycle evidence, T10, T11	G

ID	Required outcome and measurement	Future evidence / tests	Stage
R08	Role-to-resource matrix with at least twelve explicit allow/deny cases, including same-zone controls; revoke a user's resource access within a measured target of fifteen minutes after policy change	Policy matrix, revocation timing, T06, T12	H, K
R09	Evaluate Tailscale and Twingate sequentially in separate lab-only environments; scoped identities/devices, MFA, one named resource per pilot, denied-user and revocation tests; no subnet-wide or exit-node exposure	Separate pilot reports and limitation matrix, T13, T14	I
R10	Collect at least six source classes: firewall, hypervisor, directory, Windows endpoint, Linux endpoint, and remote access; at least 95% of a 20-event synthetic set searchable within five minutes, clock offsets at most two seconds, thirty-day retention design with capacity proof	Ingestion/clock/retention measurements, T15, T16	J
R11	No secrets, actual internal addresses, sensitive identities, production exports, or proprietary source in public artifacts or published history; every evidence artifact individually reviewed	Automated findings plus manual staged/history review, T00, T17	All
R12	Two bounded lab automation operations with reviewed targets and rollback; a repeated run makes zero unintended changes; check/diff output reviewed privately	Change summary and repeat-run result, T18	L
R13	Encrypted, off-compute backup of representative identity/application material; demonstrate a restore with proposed RPO at most 24 hours and RTO at most four hours; document excluded assets and dependency order	Timed isolated recovery and backup-age record, T19	L
R14	Execute every approved mandatory test; 100% of critical tests pass and at least 95% of applicable noncritical cases pass; no unresolved high-severity issue; owner UAT separately recorded	Traceability and independent observations, T01-T20	K, L
R15	Complete assignment, stage guide, architecture, threat model, decisions, risks, and report; each claimed achievement references reviewed evidence; all local Markdown links resolve	Repository validation and evidence index, T00, T20	Task 001, L
R16	Public repository uses `main`, controlled task branches/PRs after bootstrap, read-only documentation CI, reviewed commits, and exact local/remote synchronization	Git/CI verification and PR conventions, T00	Task 001, all

5. Scope, exclusions, assumptions, and constraints

In scope: design and later approved construction of a virtual-first lab, synthetic enterprise identities/data, controlled DNS/PKI, host and network policies, two separate remote-access pilots, lightweight central logging, bounded automation, and recovery verification.

Out of scope: production deployment, corporate Microsoft 365 integration, PE-DAP code or configuration, production website or hosting changes, AWS Lightsail production resources, real customer records, cross-forest or cloud production federation, public service exposure, offensive testing outside approved

synthetic lab targets, licensing selection, high availability, clustering, and certification/compliance claims.

Supplied hardware is a Dell Precision 5820 (Xeon W-2125, 80 GB RAM, 512 GB NVMe), a Lenovo Xeon laptop (119 GB RAM), an HP 410-019 (16 GB RAM, at least 250 GB storage), additional Windows/Linux test laptops, and Google Wifi mesh. These are owner-supplied descriptions, not an inspected inventory. NIC counts, firmware, disk contents, usable capacity, CPU support, OS support, ownership, and backup suitability remain unverified.

Do not assume any planned technology is installed. Work within existing hardware where feasible. Disk capacity and safe physical uplink separation are likely constraints; a single NVMe is not resilient storage. No budget, evaluation-license entitlement, remote-access subscription, or additional hardware purchase is authorized by this assignment.

6. Prerequisites and dependencies

Before each stage, obtain owner approval for that stage and resolve its blocking decisions. Required prerequisites include a dedicated lab administrator identity, physical console access, confirmed disk backups before installation, independently recorded recovery instructions, official installation media with integrity verification, evaluation/license terms, a private inventory/secrets store, and an approved isolation/egress topology. The offline baseline does not require a home network change.

The detailed dependency chain is A -> B -> C -> D -> E -> F -> G -> H -> I -> J -> K -> L. Minimal local logging and backups start with the first installed component; centralized aggregation is finalized in J. Stage I additionally requires approved isolated egress, lab-only external identities, vendor plan verification, and an MFA/recovery plan. If egress cannot be separated safely, keep the pilot pending rather than weaken isolation.

7. Expected architecture and trust boundaries

Use the Dell as a proposed single virtualization host, subject to Stage A verification. Separate management, identity/PKI, user endpoints, application services, monitoring, and remote-access connector zones using private virtual bridges with no physical ports. An optional, separately approved egress bridge may connect only the firewall WAN to a dedicated uplink. The default baseline remains disconnected from home and production networking.

Proxmox is the hypervisor management plane. OPNsense enforces inter-zone and egress policies. Active Directory supplies lab identity; host/application authorization remains necessary even when a packet is permitted. A powered-off root CA with no virtual NIC anchors a separate issuing CA. A dedicated administrative path, central event collectors, and scoped remote-access components support control and investigation. See the architecture and flow matrix.

Map NIST's logical policy engine/administrator/enforcement roles to a combination of documented authorization policy, directory/remote-access administration, firewall/host controls, and application authorization. The lab is a bounded approximation: segmentation or deploying a VPN product alone does not establish full Zero Trust maturity.

8. Technologies and implementation alternatives

Table 3. Technologies and implementation alternatives

Capability	Proposed approach	Alternative and decision condition
Virtualization	Proxmox VE on verified dedicated hardware	Existing supported Hyper-V or another hypervisor if bare-metal use is not approved; document a design change
Boundary enforcement	Virtual OPNsense with isolated bridges	Physical firewall and managed switch in a future approved expansion
Directory	Windows Server Evaluation, AD DS, DNS, GPO	An isolated Linux directory may support a comparison but cannot silently replace AD learning outcomes
PKI	Offline standalone root and AD CS issuing CA	A simpler lab CA reduces complexity but requires an explicit R07 exception and revised acceptance
Remote access	Separate Tailscale and Twingate pilots	Choose one for later operation only after documented comparison; neither connects to corporate tenants
Monitoring	Windows Event Collector plus Linux/syslog collection	Add a SIEM only after storage/resource review and approval; it is not installed by this task
Automation	PowerShell, Python, Ansible	Use the smallest supported tool for the approved operation; avoid overlapping automation ownership
Repository checks	Standard-library Python and GitHub Actions	Add dependencies only for a demonstrated gap with an approved supply-chain review

These are proposed choices. Confirm owner approval, supported versions, and compatibility before the relevant stage. Use the official technical references; do not copy an unverified deployment command into an execution record.

9. Security requirements and threat model

Protect home/production separation, administrative authority, directory credentials, CA keys, synthetic resource integrity, audit trails, and repository publication. Model a compromised ordinary endpoint, stolen lab credentials, a misconfigured connector, an overly broad firewall rule, a malicious or mistaken privileged user, supply-chain changes, and accidental data publication.

For each threat, identify entry point, trust boundary, prevention, detection, safe validation, and residual risk in SECURITY-REQUIREMENTS.md. Use default deny, separate standard/admin identities, explicit resource authorization, scoped DNS and remote access, private secrets storage, and recovery evidence. No production attacks or real credential collection are permitted.

10. Standards alignment

The tailored control matrix links requirement/test IDs to NIST SP 800-207 principles, NIST SP 800-53 Rev. 5 controls (Release 5.2.0 baseline reference), and CIS Controls v8.1. It is a project-authored mapping for learning and review, not an official crosswalk or an assertion of compliance. Consult the current catalogs linked in REFERENCES.md before implementation.

11. Deliverables and final outcomes

Task 001 establishes the assignment, architecture, A-L guide, requirements, threat/control matrix, test and acceptance plans, decision/risk registers, repository scaffold, validation code/tests, and safe GitHub publication. Its results are recorded in T1 rather than inferred from this assignment.

Later approved stages must deliver the isolated lab; reviewed inventory/design summaries; role and flow matrices; directory, Group Policy (GPO), and PKI baselines; two remote-access comparisons; monitoring evidence; two bounded automations; a timed recovery report; a requirements/test/evidence index; separate owner UAT records; and a project-level final assessment with stated limitations. Each task must also finalize its own report. These are required future deliverables, not completed lab outcomes.

12. Testing and acceptance

Use predeclared synthetic sources, destinations, identities, and expected outcomes. Positive tests prove required workflows; negative tests prove denied reachability or authorization; security tests evaluate scoped controls; recovery tests prove restoration. Tests that would touch a protected network use lab-owned mock destinations and policy inspection instead. Security tests require separate stage approval.

Each test needs a second observation and a reviewed public-safe evidence record. A critical failure blocks acceptance. Mark unexecuted tests NOT TESTED, state unsupported functions as gaps, and record any owner-approved exception with its remaining risk. See the test procedures and acceptance gates. Repository checks establish documentation/Git quality only.

13. 100-point evaluation rubric

Table 4. 100-point evaluation rubric

Assessment area	Points	Evidence required for full credit
Business analysis and governance	8	Clear role workflows, scope, approvals, decisions, and risk ownership
Architecture and capacity	12	Defensible boundaries, sizing, dependency model, and realistic limitations
Isolation and network enforcement	15	Reviewed deny-by-default rules, no protected-network path, positive and mock-negative evidence
Directory and endpoint identity	12	Separate forest, synthetic roles, DNS/GPO, hardened Windows/Linux endpoints
PKI and certificate lifecycle	10	Offline root, scoped issuing CA, issuance/trust/expiry/revocation demonstration
Least privilege and resource authorization	10	Twelve role/resource cases, same-zone enforcement, measured revocation
Remote-access comparison	8	Separate Tailscale/Twingate pilots, MFA, narrow resources, negative/revocation evidence

Assessment area	Points	Evidence required for full credit
Monitoring and audit analysis	8	Six source classes, measured ingestion/clock targets, retention capacity and investigation
Validation and recovery	10	Traceable critical tests, independent observations, timed isolated restore, separate owner UAT
Repeatable automation	4	Two reviewed operations with repeat-run evidence and rollback
Public portfolio and final reporting	3	Sanitized evidence, working documentation/CI, synchronized Git, accurate achievements

Total: **100 points**. Assess each row as demonstrated, partly demonstrated, or absent against its evidence, with a written score rationale. Planning artifacts alone earn no implementation points. Production integration, secret publication, or an unresolved critical safety test prevents final acceptance regardless of score. An owner-approved scope exception must revise requirements and scoring before evaluation.

14. GitHub publication requirements

Use the authorized public repository under `waqashamdani-ca`, default branch `main`, and a supported secure credential store. Check for existing remote work and reconcile it without overwriting or force-pushing. Publish only reviewed project artifacts, using a noreply commit email; no license is selected in Task 001.

Scan the entire proposed file set, staged diff, and history for secrets, actual internal addresses, sensitive identities, images/log metadata, production exports, and proprietary source. Exclude raw evidence and private inventories. Use least-privilege documentation CI; do not connect Actions to the lab. For future work use focused task branches, checks, PR review, and fast-forward synchronization as defined in AGENTS.md. Confirm remote URL, visibility, default branch, commit equality, clean status, and actual CI outcome.

15. Evidence-backed resume achievement objectives

These are future writing patterns, not current achievements:

- "Designed and validated an isolated six-zone security lab" only after linking its reviewed topology, capacity record, and passed boundary tests.
- "Implemented role-scoped access for six synthetic users and separate administrators" only after directory, host, resource, and negative-test evidence exists.
- "Evaluated two identity-aware remote-access approaches" only after separate pilot reports and measured denied/revoked-user behavior.
- "Collected six security event source classes with measured ingestion latency" only after reporting actual sample size, observed percentage, and retained evidence.
- "Demonstrated recovery within a measured RTO" only after a timed restore, stated recovery scope, and verified service behavior.

State exact observed measurements and lab scope, cite evidence IDs, and disclose limitations. Do not claim production impact, CISSP certification, compliance, penetration-test outcomes, or unavailable implementation results.

16. Authoritative references

Use the maintained reference catalog for NIST, CIS, Proxmox, OPNsense, Microsoft, IETF, Tailscale, Twingate, Ansible, systemd, and GitHub. References were researched for the bootstrap on 2026-11-05; recheck current versions, licensing, security advisories, and exact syntax before a future stage is approved.